

Bryan Kim Calipes

ACTIVITY 2B: Information Security Risk Assessment & Accountability Exercise

Part 1: Data Sensitivity & Risk Awareness

1. Patient medical records

- Classification: Highly Confidential/Restricted
- Risk Explanation: These records contain private health information about patients. If someone gets access to them without permission, the clinic could get sued, patients could lose trust in the clinic, and it violates privacy laws. People's medical conditions should stay private.

2. Employee work schedules

- Classification: Internal
- Risk Explanation: Work schedules are meant for staff only. If these get leaked, outsiders could know when the clinic has less staff working, making it easier to plan theft or other bad activities. It's not super sensitive but should stay inside the organization.

3. Public health announcements posted on the clinic's Facebook page

- Classification: Public
- Risk Explanation: These are already shared publicly so there's no real risk from people seeing them. The clinic wants everyone to read these announcements to help the community stay healthy.

4. Patient contact information (email addresses and phone numbers)

- Classification: Confidential
- Risk Explanation: If this information gets out, scammers could use it to send fake emails or make spam calls pretending to be from the clinic. Patients might get tricked into giving money or personal information to criminals.

5. Patient portal usernames and passwords

- Classification: Highly Confidential/Restricted
- Risk Explanation: These are the keys to accessing patient accounts. If hackers get these, they can log in as patients and steal medical records, change appointment information, or cause serious damage. This could destroy the clinic's reputation completely.

Part 2: CIA Triad-Based Risk Analysis

Asset 1: Patient Management System

Confidentiality Risks: The system could be accessed by unauthorized people if passwords are weak or if staff members share their login information. Someone could also look at patient records they're not supposed to see, or hackers could break into the system from outside.

Integrity Risks: Patient information could get changed by mistake if staff aren't trained properly. Someone could accidentally delete records or update the wrong patient's file. Hackers could also change medical information on purpose to cause harm.

Availability Risks: The system could crash or stop working if there's a cyber-attack or technical problem. If the internet goes down, staff can't access patient information, which means appointments get delayed and the clinic can't function properly.

Risk Mitigation Measures:

- Make everyone use strong passwords and change them regularly
- Give staff members access only to the information they need for their job
- Train all employees on how to use the system correctly
- Install backup systems so data doesn't get lost
- Use antivirus software and firewalls to block attacks

Asset 2: Staff Email Accounts

Confidentiality Risks: Staff might accidentally send sensitive patient information to the wrong email address. Hackers could trick employees into giving away their passwords through fake emails. People could also read each other's emails if computers are left unlocked.

Integrity Risks: Emails with lab results or appointment details could be altered by hackers before they reach patients. Staff could send outdated or incorrect information by mistake. Attachments could get corrupted or changed without anyone noticing.

Availability Risks: Email accounts could get hacked and locked, preventing staff from communicating with patients. The email server could go down, making it impossible to send or receive important messages about appointments or test results.

Risk Mitigation Measures:

- Train staff to double-check email addresses before sending
- Use encryption for emails containing patient information
- Create clear rules about what can and can't be sent through email
- Set up two-factor authentication for all email accounts

- Make staff log out of email when they're done using shared computers

Asset 3: Reception Desktop Computers

Confidentiality Risks: Since these computers are shared, anyone at the reception desk could see patient information left on the screen. Visitors might peek at the monitor and see private details. Without proper security, someone could steal patient data from these computers.

Integrity Risks: Multiple people using the same computer could accidentally delete or change files. Viruses could infect the computer and corrupt patient records. Without proper controls, it's hard to know who made what changes to the system.

Availability Risks: One computer already doesn't have antivirus, so it could get infected and stop working. If malware spreads, all reception computers could crash at once, shutting down the entire check-in process and causing chaos.

Risk Mitigation Measures:

- Install antivirus software on all computers immediately
- Set computers to lock automatically after a few minutes of inactivity
- Create separate user accounts for each staff member
- Position monitors so visitors can't see the screens
- Block USB drives to prevent people from copying data

Part 3: Risk Mitigation & Control Recommendations

1. Security Awareness Training

- What it addresses: People
- Specific risk reduced: This training teaches staff how to recognize phishing emails, handle patient data properly, and follow security rules. It reduces the risk of employees accidentally leaking information or falling for scams. Since most security problems are caused by human mistakes, training is super important.

2. Email Usage Guidelines and Verification Policy

- What it addresses: Process
- Specific risk reduced: Clear rules about emailing patient information will prevent staff from sending sensitive data to wrong addresses. The policy should require staff to double-check email addresses and use encryption for sensitive attachments. This stops accidental data leaks like what already happened.

3. Antivirus and Endpoint Protection

- What it addresses: Technology
- Specific risk reduced: Installing antivirus on all computers protects against malware, viruses, and ransomware attacks. This is especially important since one reception computer already has no protection. It prevents hackers from stealing data or shutting down systems.

4. Access Control and User Authentication

- What it addresses: Process and Technology
- Specific risk reduced: Setting up role-based access means employees only see information needed for their job. Using strong passwords and two-factor authentication prevents unauthorized access to the patient portal and management system. This stops hackers and reduces inside threats.

5. Regular Data Backup and Recovery Procedures

- What it addresses: Process and Technology
- Specific risk reduced: Automatically backing up patient data to a secure location protects against data loss from system crashes, ransomware, or accidents. If something goes wrong, the clinic can quickly restore information and keep operating without losing important medical records.

Part 4: Accountability & Incident Response Case

1. What type of information was exposed, and why is it sensitive?

The information exposed includes patient names, test dates, and medical notes. This is extremely sensitive because it reveals people's private health conditions and connects their identity to their medical problems. Patients trust the clinic to keep this information secret and exposing it violates privacy laws and could lead to embarrassment, discrimination, or identity theft for the affected patients.

2. Which CIA principle(s) were compromised?

Confidentiality was compromised because unauthorized people gained access to private patient information they shouldn't have seen. Integrity is also at risk since the person who received the email could share, modify, or misuse the information.

3. What immediate steps should management take to limit damage?

Management should immediately contact the person who received the email and ask them to delete it without sharing it. They need to document what happened, inform the affected patients right away, and check if the email was forwarded to others. The staff member's email access should be suspended, and depending on local laws, they may need to report the breach to health authorities.

4. What policy or procedural failures contributed to this incident?

The clinic lacks a clear policy about handling patient information through email and has no requirement to verify email addresses before sending sensitive data. Staff weren't properly trained on data protection, and there's no email encryption or approval process before sending patient information externally.

5. What long-term actions should be implemented to prevent recurrence?

The clinic should create a strict policy requiring staff to verify email addresses before sending patient data and implement email encryption or switch to a secure patient portal. They need to provide regular security training for all staff, set up email warnings for external addresses, conduct regular audits of data handling practices, and establish clear consequences for policy violations.

6. Who should be informed or notified, and why?

The affected patients must be notified so they can watch for identity theft or scams. Government health authorities need to know because laws require reporting medical data breaches. The clinic's management and legal team should be informed to handle potential lawsuits, the insurance company needs to know about possible claims, and all clinic staff should learn from this incident as a training example.

Part 5: Reflection

Information security failures can completely destroy a healthcare organization's reputation because patients will stop trusting them with their private medical information. When data breaches happen, the clinic could face huge fines and lawsuits for breaking privacy laws, which could even force them to shut down. It's not just about protecting computers and systems, it's about protecting real people's privacy and the clinic's ability to stay in business. Once patients lose trust in a clinic, they'll go somewhere else, and the clinic will lose money and possibly have to close. Good security practices show patients that the clinic respects them and takes their privacy seriously, which is essential for any healthcare business to survive.